

Portfolio Desk Data Retention and Disposal Policy

Field	Value
Document owner	Privacy Officer or designated data governance owner
Security owner	Information Security Officer or designated security owner
Business owner	Portfolio Desk executive sponsor
Version	1.0
Effective date	Upon management approval
Review frequency	At least annually and after material legal, contractual, or architectural changes
Classification	Internal
Approval status	Draft for management approval

1. Purpose

This policy establishes requirements for retaining, archiving, deleting, anonymizing, and securely disposing of information processed by Portfolio Desk. It is intended to:

- Retain information only as long as necessary for approved business, contractual, legal, security, and operational purposes.
- Protect customer and personal information throughout its lifecycle.
- Provide consistent handling of account termination, record deletion, legal holds, backups, integrations, and derived data.
- Reduce security, privacy, litigation, and operational risk created by unnecessary data accumulation.
- Provide evidence that disposal actions are authorized, complete, and auditable.

This policy supplements the Portfolio Desk Information Security Policy and Privacy Policy. Applicable law, court orders, legal holds, signed customer agreements, and documented regulatory requirements take precedence when they require a different retention period.

2. Scope

This policy applies to:

- Production, development, test, staging, backup, disaster recovery, and support environments.
- Portfolio Desk databases, uploaded documents, object storage, logs, caches, search indexes, embeddings, exports, reports, email records, and local or cloud backups.
- Customer, user, resident, applicant, owner, vendor, landlord, employee, and support information processed by Portfolio Desk.
- Commercial and residential leases, property records, accounting records, maintenance records, waivers, insurance certificates, and related attachments.
- Authentication data, audit logs, security telemetry, support records, and billing records.
- Third-party integrations and service providers, including Stripe, QuickBooks Online, Plaid, email providers, identity providers, AI providers, Sentry, cloud hosting, and backup services.
- Employees, contractors, administrators, developers, support personnel, and service providers who create, access, export, archive, or dispose of Portfolio Desk information.

3. Principles

Portfolio Desk shall apply the following principles:

1. **Purpose limitation:** information shall be retained only for a documented purpose.
2. **Data minimization:** collection and retention shall be limited to information reasonably needed for that purpose.

3. **Tenant isolation:** retention and disposal actions shall preserve organization boundaries and shall not expose or delete another organization's information.
4. **Least privilege:** only authorized roles may approve or execute disposal.
5. **Legal preservation:** legal holds suspend ordinary deletion for affected information.
6. **Complete lifecycle handling:** disposal shall address primary records, attachments, derived records, search indexes, caches, integrations, and backups.
7. **Verifiability:** material disposal actions shall produce evidence sufficient to show what was deleted, by whom, when, and under what authority.
8. **Secure disposal:** deleted information shall not remain practically recoverable from active systems after the approved disposal process completes.

4. Roles and Responsibilities

4.1 Data governance owner

The data governance owner shall:

- Maintain the retention schedule and approve changes.
- Coordinate legal, contractual, privacy, accounting, and customer requirements.
- Approve disposal procedures and material exceptions.
- Ensure data inventories identify systems of record, derived stores, and third-party processors.

4.2 Security owner

The security owner shall:

- Define secure disposal methods.
- Review access to retained and archived information.
- Coordinate legal holds and incident-related preservation with authorized stakeholders.

- Verify that disposal jobs, backup lifecycle controls, and vendor deletion processes are monitored.

4.3 System and data owners

System and data owners shall:

- Assign each information category to an approved retention period.
- Ensure products and workflows support the required retention and disposal behavior.
- Review retained information at least annually.
- Document any operational dependency that prevents timely disposal.

4.4 Engineering and operations

Engineering and operations shall:

- Implement approved pruning, deletion, anonymization, backup expiry, and reindexing controls.
- Test disposal procedures and preserve evidence of execution.
- Prevent deleted information from being unintentionally recreated from queues, caches, replicas, imports, or integrations.
- Escalate failed or incomplete disposal tasks.

4.5 Customer organizations

Customer organizations control the business content entered by their users, subject to Portfolio Desk's contractual role and applicable law. Customers are responsible for configuring and using the service consistently with their own legal and records-management duties.

5. Retention Schedule

The following schedule defines Portfolio Desk defaults. A signed customer agreement, legal hold, or documented legal requirement may supersede a default. Retention periods are measured from the event listed in the final column.

Information category	Default active-system retention	Trigger or notes
Organization account and configuration	Duration of active service plus 90 days	Begins when the organization is canceled or deactivated; Restricted secrets follow shorter periods below
User accounts and role assignments	Duration of active service plus 90 days	Access is disabled promptly when no longer authorized; identity evidence may be retained with audit records
Commercial and residential property records	Duration of active service plus 90 days	Includes offices, units, spaces, residents, owners, landlords, vendors, transitions, and related operational records
Lease records and lease documents	Duration of active service plus 90 days, or 7 years after lease termination when retained for accounting or legal purposes	The longer applicable period controls
General ledger and financial transactions	7 years after the close of the fiscal year	Includes journal entries, account mappings, AP, AR, CAM, rent, deposits, bank reconciliation, budgets, tax records, and lease accounting schedules
Signed waivers and signature evidence	7 years after signing or contract	Includes signed PDFs, consent, attribution,

Information category	Default active-system retention	Trigger or notes
	termination, whichever is later	hashes, IP and user-agent evidence where collected
Maintenance, HVAC, inspection, and transition records	3 years after closure, or longer when linked to an active claim, contract, warranty, or legal requirement	Safety, insurance, and warranty requirements may extend retention
Insurance certificates and vendor compliance records	7 years after expiration or termination of the vendor relationship, whichever is later	Supports claims and compliance evidence
Contacts and routine communications	Duration of active relationship plus 3 years	Excludes records incorporated into a longer-lived legal, financial, support, or audit record
Tenant screening summaries	Minimum period needed for the leasing decision, dispute, and legally required adverse-action process	The responsible customer must define the applicable schedule; raw reports and unnecessary sensitive fields shall not be retained
Support requests and customer service records	3 years after closure	Security incidents and contractual disputes follow their longer applicable schedules

Information category	Default active-system retention	Trigger or notes
Billing and subscription records	7 years after the transaction or fiscal-year close	Payment card numbers are not stored by Portfolio Desk
Application audit logs, Core plan	90 days	Implemented through nightly organization-scoped pruning
Application audit logs, Operations and Enterprise	Duration of active service by default	Contract or approved organization override may establish a finite period; post-termination rules still apply
Authentication and security logs	1 year where collected and operationally available	Longer retention may apply to incidents, investigations, or contracts
Application and infrastructure logs	90 days by default	Logs shall exclude secrets and unnecessary customer content; production log-platform configuration must enforce the period
Security incident records	7 years after closure	Includes investigation, evidence, notifications, corrective actions, and lessons learned
Integration OAuth tokens and connection secrets	Until disconnect, revocation, expiration, or organization termination	Delete promptly when no longer needed; revoke at the provider where supported

Information category	Default active-system retention	Trigger or notes
Integration mappings, cursors, and sync history	Duration of connection plus 90 days, unless part of a 7-year financial record	Financial transaction provenance follows the financial-record period
AI prompts and provider responses stored by Portfolio Desk	Same period as the parent business record	Provider-side retention is governed by approved provider terms and configuration
Embeddings and semantic-search chunks	Until the source record is deleted or reindexed	Remove or rebuild promptly after source deletion or embedding-model changes
Temporary uploads and processing artifacts	No longer than 24 hours after processing unless promoted to a business record	Temporary files shall not become an undocumented archive
Exports and generated reports	30 days when stored by Portfolio Desk	User-downloaded copies are controlled by the receiving customer
Local in-process caches	Until process restart or configured cache expiry	Caches shall not be the system of record
Daily S3 application backups	3 days under the current backup lifecycle	Applies to documented <code>pg_dump</code> and uploaded-file backup sets
Managed database snapshots	7 days by default where configured	Deployment-specific settings may provide a longer approved period

Information category	Default active-system retention	Trigger or notes
Source code and deployment records	Life of the product plus 7 years	Secrets and production customer data are prohibited from source control

6. Account Termination and Organization Deletion

6.1 Access termination

When an organization is canceled or requests deletion:

- Organization access shall be disabled promptly.
- Active sessions and API access shall be revoked or allowed to expire according to the approved termination procedure.
- Billing subscriptions shall be canceled according to contract terms.
- Scheduled communications, synchronization jobs, webhooks, and other outbound processing shall stop.
- Customer exports shall be offered before deletion when contractually required and legally permitted.

6.2 Post-termination holding period

Customer business data shall enter a restricted post-termination holding period of no more than 90 days unless a legal hold, contract, or longer category-specific requirement applies. During this period:

- Customer users shall not retain ordinary application access.
- Access shall be limited to authorized operations, security, privacy, legal, or support personnel with a documented purpose.
- Data shall not be used for product development, analytics, or unrelated purposes.
- Restoration shall require documented authorization.

6.3 Final disposal

At the end of the applicable holding period, Portfolio Desk shall:

1. Identify organization-owned records and dependent records.
2. Preserve records subject to legal, tax, accounting, claims, or contractual retention.
3. Delete or irreversibly anonymize remaining active-system data.
4. Delete uploaded files and generated documents from active storage.
5. Remove search chunks, embeddings, cached copies, and queued work.
6. Revoke and delete third-party integration credentials.
7. Stop webhooks, email rules, scheduled reports, and background jobs for the organization.
8. Record a non-sensitive disposal certificate or administrative audit event.
9. Allow residual encrypted backup copies to age out under the backup lifecycle.

Current organization deletion endpoints deactivate an organization and preserve its data. They do not constitute final disposal. Final disposal requires an approved purge procedure or a verified manual process until automated organization purging is implemented.

7. Record-Level Deletion and Soft Delete

- Soft deletion removes a record from ordinary workflows but does not satisfy a final deletion request.
- Soft-deleted operational records shall be recoverable only by authorized roles and shall retain organization scope.
- Unless a longer schedule applies, soft-deleted records shall be permanently purged within 30 days.
- A parent record shall not be purged until dependent legal, financial, audit, attachment, and integration records have been evaluated.
- Where referential integrity prevents deletion, data shall be anonymized or retained under an approved exception with documented justification.
- Restoring a soft-deleted record shall create an attributable audit event.

Portfolio Desk does not currently provide a universal automated 30-day purge for all soft-deleted entity types. This is an implementation requirement and shall remain tracked until completed.

8. Legal Holds and Preservation

A legal hold suspends normal alteration and deletion for information reasonably related to litigation, investigation, subpoena, audit, claim, dispute, or regulatory inquiry.

- Only authorized legal, compliance, privacy, or executive personnel may issue or release a legal hold.
- Hold notices shall identify scope, custodians, systems, organizations, date ranges, and responsible owner.
- Engineering and operations shall suspend affected pruning, account purge, backup expiry where feasible, and third-party deletion.
- Held information shall be access controlled and shall not be modified except through an approved evidence process.
- The hold owner shall review active holds at least quarterly.
- When a hold is released, the ordinary retention schedule resumes. Information already past its retention period shall be disposed of promptly.

9. Privacy and Data Subject Requests

- Requests to access, correct, export, restrict, or delete personal information shall be authenticated before fulfillment.
- When Portfolio Desk processes Customer Data on behalf of a customer organization, requests concerning that data shall be coordinated with the customer as data controller.
- Requests shall be logged and completed within the applicable legal or contractual deadline. The operational target is 30 calendar days unless a shorter requirement applies.
- Deletion requests shall be evaluated against legal holds, financial retention, fraud prevention, security evidence, and contractual obligations.

- Where full deletion is not permitted, information shall be restricted and retained only for the applicable obligation.
- Responses shall disclose material limitations, including backup expiry and customer-controlled downloaded copies.

10. Backups, Replicas, and Disaster Recovery Copies

- Backup systems shall have documented lifecycle rules and shall not become indefinite archives.
- The current application backup process retains daily database and uploaded-file backup sets for three days. Managed production database snapshots default to seven days where configured.
- Deleted active-system data may remain in encrypted backups until the backup naturally expires.
- Backups shall not ordinarily be altered to remove a single record because doing so can undermine integrity and recoverability.
- If a backup is restored, disposal actions that occurred after the backup was created shall be replayed before the restored environment is returned to service.
- Backup access shall be restricted and logged where supported.
- Failed lifecycle deletion or backup jobs shall be investigated and corrected.
- Legal holds requiring backup preservation shall use a separately controlled preserved copy with an owner and expiration review.

11. Logs, Audit Records, and Security Evidence

- Audit-log visibility and physical deletion are distinct controls. Portfolio Desk physically prunes Core-plan activity logs older than 90 days through a nightly batch job.
- Operations and Enterprise currently have unlimited active-service audit retention unless overridden. Data owners shall periodically confirm that continued retention remains necessary.
- Application logs shall not contain passwords, API keys, access tokens, refresh tokens, encryption keys, full connection strings, or unnecessary

document content.

- Security events under investigation shall be copied to controlled evidence storage before ordinary log expiry.
- Disposal logs shall contain identifiers and counts sufficient for verification but shall not reproduce the deleted sensitive content.

12. Uploaded Files and Object Storage

- Uploaded files inherit the retention period of their parent record unless a separate legal or contractual requirement applies.
- Deleting database attachment metadata without deleting the corresponding object does not satisfy disposal.
- Object deletion shall include active objects and shall rely on storage lifecycle controls to expire noncurrent versions where versioning is enabled.
- File exports and signed documents shall be disposed of according to their record category.
- Temporary processing files shall be stored in controlled locations and removed after processing.
- Local disks, Docker volumes, S3 buckets, and other object stores shall be included in disposal inventories.

13. Financial and Accounting Records

- Posted journals and finalized financial records shall not be silently modified or deleted to fulfill an ordinary application cleanup request.
- Required financial records shall be retained for seven years after fiscal-year close unless a longer legal or contractual period applies.
- Personal information not required to preserve accounting evidence shall be minimized or anonymized where practical.
- Deletion of source operational records shall preserve the integrity, balance, provenance, and auditability of retained financial records.
- QuickBooks and Plaid data retained in Portfolio Desk shall follow the same financial retention rules as equivalent locally created records.

14. External Integrations

14.1 OAuth and API connections

When an integration is disconnected or an organization terminates:

- Stored access and refresh tokens shall be deleted promptly.
- Provider-side grants or Items shall be revoked or removed where the provider supports revocation.
- Scheduled synchronization shall stop.
- Connection-specific caches and pending jobs shall be cleared.
- Mappings and sync history shall be retained only when needed for financial provenance, incident evidence, or support history.

14.2 Service-provider deletion

Contracts and configurations for subprocessors shall address retention and deletion. Portfolio Desk shall use provider deletion controls where available and shall document material provider-side retention that cannot be controlled directly.

14.3 Customer-controlled external copies

Portfolio Desk cannot delete copies previously exported to, or independently created in, a customer's QuickBooks company, bank, email system, identity provider, downloaded files, or other external system. The customer controls those copies unless Portfolio Desk has separately agreed to manage them.

15. AI Data and Derived Data

- Documents and prompts sent to AI providers shall be limited to the minimum content needed for the feature.
- Provider-side prompt, file, output, and abuse-monitoring retention shall be reviewed before enabling a provider in production.
- AI-generated suggestions stored as business records inherit the parent record's retention period.

- Temporary model responses that are not adopted shall not be retained longer than operationally necessary.
- Embeddings, extracted text, document chunks, and parse caches are derived data and shall be deleted or rebuilt when the source is deleted.
- Changing embedding providers or models requires reindexing so derived data does not persist beyond its approved purpose or produce unreliable mixed-model search.

16. Development, Test, and Support Data

- Production customer data shall not be copied into development or test environments unless approved and sanitized.
- Test organizations and synthetic data shall be deleted when the test purpose ends, and at least every 90 days for persistent non-production environments.
- Debug exports, screenshots, database dumps, and support attachments shall be treated according to the sensitivity of their source data.
- Local developer copies containing Confidential or Restricted data shall be prohibited unless explicitly authorized, encrypted, inventoried, and time-limited.
- Temporary troubleshooting access and files shall be removed when the support case closes.

17. Secure Disposal Methods

Approved disposal methods include:

Storage type	Approved method
PostgreSQL records	Transactional hard deletion, approved anonymization, or cryptographic destruction of a dedicated encrypted store
Object storage	Object deletion plus configured expiration of noncurrent versions and delete markers
Local files and Docker volumes	Secure deletion where supported, volume destruction, or destruction of the encrypted

Storage type	Approved method
	storage key
Backups	Lifecycle expiration, secure deletion of preserved copies, or cryptographic erasure
OAuth and API credentials	Local token deletion plus provider revocation or Item removal where supported
Search indexes and embeddings	Organization-scoped deletion followed by index synchronization or rebuild
Logs	Retention-platform expiry or controlled deletion preserving required incident evidence
Physical media	Provider-certified sanitization or destruction appropriate to media type
Paper	Cross-cut shredding or approved secure destruction service

Deletion commands shall be scoped, reviewed, and tested to prevent cross-tenant or excessive deletion. Large or irreversible purge operations require a backup and a second-person review unless an approved automated job performs a previously tested procedure.

18. Disposal Authorization and Evidence

Material disposal shall require:

- A verified request or scheduled retention event.
- Identification of the organization, data categories, date range, and systems involved.
- Confirmation that no legal hold applies.
- Approval from the data owner or authorized delegate.
- A reviewed execution plan for irreversible or bulk deletion.
- Verification of completion and exception handling.

Evidence shall include:

- Request or schedule identifier.

- Approver and executor.
- Start and completion time.
- Systems and providers addressed.
- Record or object counts where practical.
- Failures, residual copies, backup expiry dates, and follow-up actions.

Disposal evidence shall avoid retaining the deleted content itself and shall follow the security-incident or audit-record schedule as applicable.

19. Monitoring and Control Testing

- Automated pruning and lifecycle jobs shall emit success, failure, duration, and deletion-count information.
- Operations shall review failed disposal jobs promptly.
- Backup lifecycle configuration, audit pruning, object version expiry, integration disconnect, and organization purge shall be tested at least annually.
- Tests shall verify organization scope and confirm that one organization's disposal cannot affect another organization.
- A sample of completed deletion requests shall be reviewed periodically for completeness across active data, files, derived stores, integrations, and backups.
- Identified gaps shall be tracked with an owner, target date, and risk rating.

20. Exceptions

Exceptions require written documentation of:

- The affected data and system.
- The policy requirement and requested alternative period.
- Legal, contractual, business, and security justification.
- Risks and compensating controls.
- Accountable owner and approver.
- Effective and expiration dates.
- Review frequency and final disposal action.

Exceptions shall be time-bound. Retaining information "just in case" is not sufficient justification.

21. Enforcement

Failure to comply may result in access restriction, corrective action, contract remedies, or disciplinary action consistent with applicable agreements and law. Disposal may be suspended where execution would violate a legal hold, compromise an investigation, or create a greater documented security risk.

22. Review and Approval

This policy shall be reviewed at least annually and after:

- Material changes to data categories, legal obligations, customer contracts, integrations, hosting, backups, or AI providers.
- A significant security or privacy incident.
- An audit finding involving excessive retention, incomplete deletion, or recovery of disposed data.
- Implementation of organization hard purge or universal soft-delete pruning.

Revisions and approvals shall be retained.

Appendix A: Current Implementation Profile and Gaps

Area	Current behavior	Required action or qualification
Organization deletion	Customer and super-admin delete endpoints deactivate the organization and cancel billing; data is preserved	Implement or document a verified final purge process after the approved holding period
Soft-deleted entities	Several operational entities support trash and	Implement universal 30-day purge or approve

Area	Current behavior	Required action or qualification
	restore	category-specific exceptions
Audit logs	Core organizations are pruned nightly after 90 days; Operations and Enterprise default to unlimited	Periodically review unlimited retention and support finite contractual overrides
Backups	S3 database and upload backups expire after 3 days; AWS managed database snapshots default to 7 days where configured	Monitor lifecycle jobs and test restoration and post-restore reapplication of deletions
Uploaded files	Stored locally or in S3 and associated through attachment records	Verify object deletion accompanies metadata purge and covers noncurrent versions
QuickBooks	Disconnect deletes the local encrypted connection and mappings according to database relationships	Confirm provider-side revocation procedure and retain only required financial provenance
Plaid	Disconnect calls Plaid Item removal and deletes the local encrypted connection	Verify imported financial records follow the 7-year schedule independently of the token
AI parse cache	In-process cache expires on process restart or eviction	Add explicit source-deletion invalidation if persistent cache behavior is introduced

Area	Current behavior	Required action or qualification
Embeddings	Organization-scoped chunks and vectors support rebuild	Ensure source deletion triggers derived-data removal and vector synchronization
Logs	Structured logging and optional external error tracking are available	Configure and evidence production retention in each logging provider
Legal holds	Policy process defined in this document	Implement an operational hold register and deletion-job suppression procedure
Disposal evidence	Activity and job logs provide partial evidence	Implement a standard disposal certificate or ticket checklist for organization purge

Appendix B: Related Documents

- docs/INFORMATION_SECURITY_POLICY.md
- backend/app/legal/documents/privacy-policy.md
- backend/app/legal/documents/terms-of-service.md
- docs/backup-setup.md
- docs/INTEGRATIONS.md
- docs/AI_PROVIDERS.md
- docs/OBSERVABILITY.md
- docs/RLS_EVALUATION.md
- backend/docs/TENANT_SCOPING.md
- docs/ACCOUNTING_AUDIT.md
- docs/MIGRATIONS.md